ConsentChain: PureChain-Powered Verifiable Machine Unlearning and Dynamic Consent for Federated IoT Learning

Josiah Ayoola Isong, Oroceo Paul Angelo, Jae-Min Lee, Dong-Seong Kim (SMIEEE)
Department of IT Convergence Engineering, Kumoh National Institute of Technology, Gumi, South Korea
isongjosiah@gmail.com,(ljmpaul, dskim)@kumoh.ac.kr

***Abstract*—Federated learning over consumer IoT devices must now honour data-subject withdrawal under GDPR, the EU AI Act, and CCPA: consent can be revoked and the trained model must demonstrably forget. Prior work treats consent management, machine unlearning, and on-chain auditability as disjoint threads. We close the *consent–unlearning–verification triangle* with ConsentChain, a protocol binding all three in a single chain-enforced pipeline: a Consent Lifecycle State Machine (CLSM) as soulbound ERC-721 tokens; a Verifiable Unlearning Protocol gating on-chain acceptance on three independent membership-inference attacks; a three-contract Solidity architecture on a gas-free (PureChain, PoA^2) and a gas-based (Polygon Amoy, PoS) chain; and a dual-domain evaluation on N-BaIoT and CASAS. Per-subject lifecycle cost is $0 on PureChain versus $0.00120 on Amoy; the gate accepts approximate unlearning (MIA < 0.55) yet rejects naive retraining—whose distributional uniqueness inflates MIA—and any attestation lacking a 3-of-5 verifier threshold, proving it faithful to MIA evidence rather than the controller's claim.**

***Index Terms*—federated learning, machine unlearning, smart contracts, dynamic consent, IoT, GDPR, EU AI Act, membership inference attack**

I. Introduction

Federated learning (FL) trains a shared model across decentralised clients without centralising their data [1], often the only legally viable option in consumer IoT. Beyond *technical* privacy (secure aggregation, leakage bounds), a second, equally binding axis is under-addressed: *regulatory* privacy. GDPR Article 7 requires consent to be purpose-granular and freely withdrawable, and Article 17 grants erasure—which, for a trained model, means it must *forget* a revoked participant; the EU AI Act [2] (Arts. 15/26) and CCPA [3] §1798.105 impose analogous, auditable duties. Each demands demonstrable, audit-grade evidence, not a promise to comply.

Three research threads each address one corner. Consent-management ledgers (MedRec [4]) record consent but cannot gate training; machine-unlearning methods (SISA [5], FedEraser [6]) remove a contribution but leave trigger and verification off-chain; and blockchain-FL systems [7], [8] log updates without consent semantics or forgetting verification. No work binds the three.

We frame the gap as a missing *edge*, not a missing vertex: consent must remain authoritative over which data enters each round, unlearning (by any method) must be *verifiable* rather than self-asserted, and verification against membership inference [9]–[11] must in turn drive the consent state, closing the loop. Prior work implements the vertices; ConsentChain supplies the edges. Enforcing this off-chain merely moves trust to the controller; a public, gas-free, PoA^2 substrate removes it at *exactly* $0 per operation, where a gas-based chain would charge dollars per revocation—prohibitive at IoT scale. This work makes four contributions: (1) a **Consent Lifecycle State Machine** (CLSM)—six states, nine transitions, four formally-stated safety and liveness properties, instantiated as a soulbound ERC-721 contract; (2) a **Verifiable Unlearning Protocol** (VUP), method-agnostic over the unlearning algorithm, accepting an attestation iff three *independent* membership-inference attacks (shadow [9], LiRA [10], label-only [11]) all fall below τ under t-of-n ECDSA signatures; (3) a **three-contract Solidity architecture** (ConsentRegistry, UnlearningOracle, FLGatekeeper) deployed on *both* a gas-free (PureChain, PoA^2) and a gas-based (Polygon Amoy, PoS) chain—the first side-by-side cost comparison under both economic models; and (4) a **dual-domain evaluation** on a 9-client N-BaIoT [12] autoencoder federation, cross-validated on a 5-client CASAS BiLSTM classifier, across three approximate-unlearning paradigms plus exact retraining, measuring forgetting, on-chain cost, and utility recovery.

II. Related Work

Three converging research threads form the prior art for ConsentChain; we summarise each with its gap, then position ConsentChain against all three.

Consent management on distributed ledgers. MedRec [4] records patient consent immutably on-chain—the durability and owner-exclusive control we inherit—but treats the record as the protocol *endpoint*: no training is gated by it, and nothing shows a withdrawal produced a model update (semantic-web vocabularies like GConsent formalise consent off-chain without enforcement). *Gap*: consent is recorded but does not influence training.

Machine unlearning. SISA [5] pre-shards data so removal retrains only the affected shard; FedEraser [6] replays aggregation history with calibration; and gradient-ascent methods take a few negative-rate steps on the data to remove. None, though, specifies how unlearning is triggered, by whom, or how a deployer proves it happened. *Gap*: unlearning is implementable but not verifiable end-to-end.

Blockchain-based federated learning. BlockFL [7] logs device-side updates on-chain against malicious aggregators and BFLC [8] replaces the aggregator with committee consensus, but neither encodes consent: a joined participant cannot withdraw without trusting the orchestrator. Membership inference [9]–[11] is the canonical test for residual memorisation, yet no blockchain-FL system uses MIA scores as an on-chain acceptance criterion. *Gap*: updates are auditable but consent semantics and forgetting verification are absent.

Positioning. Across the four implicated dimensions—consent representation, unlearning trigger/method, verification, and on-chain footprint—each prior system covers at most one natively. ConsentChain is the first we are aware of to address all four in one chain-enforced protocol at gas-free cost: it adopts MedRec's registry (vertex A) under the CLSM properties, accepts any unlearning paradigm as a black box (vertex B), and makes three-MIA verification (vertex C) the gating condition for a consent transition—the missing edge prior work leaves open.

The *choice* of chain matters at IoT scale; we quantify this (Section V) against PureChain [13], a public, gas-free, EVM-compatible PoA^2 chain—not our contribution, but a substrate on which the protocol is operationally identical to a gas-based chain while the economics differ fundamentally.

III. System Model and Threat Model

A. Entities

ConsentChain has six entities. The data subject DS_i controls the private key of one soulbound Consent NFT; the data controller DC orchestrates the FL round loop and triggers unlearning on revocation; each participant device FL_k runs local SGD; the Verifier Committee $VC = \{v_1, \ldots, v_n\}$ holds $n = 5$ registered ECDSA keys with default threshold $t = 3$; and three on-chain contracts—`ConsentRegistry` (CR), `UnlearningOracle` (UO), and `FLGatekeeper` (GK)—implement the protocol; any chain reader is an *auditor*.

B. Federated learning baseline

We adopt FedAvg [1], aggregating validated clients as $\theta^{(r+1)} = \sum_{k \in K_r} (n_k / \sum_{j \in K_r} n_j)\, \theta_k^{(r+1)}$, where K_r is the participant set returned by GK.`validateRound` and n_k the local set size. The novel restriction is that K_r must be that return value, not an orchestrator-chosen subset: consent is enforced at the membership level, not the gradient level.

C. Consent Lifecycle State Machine

The CLSM is a deterministic finite automaton CLSM $= (S, \Sigma, \delta, s_0, F)$ over six states S (Inactive, Active, Suspended, Revoked, Expired, Unlearned; start state Inactive, absorbing terminal $F = \{\text{Unlearned}\}$) and eight events Σ (`grant`, `modify`, `suspend`, `resume`, `revoke`, `tick`, `expire`, `unlearn_verified`). Its nine δ transitions are: `grant` activates a token; `modify` and `tick` are Active self-edges; `suspend`/`resume` toggle Suspended; `revoke` and `expire` leave Active for Revoked/Expired; and `unlearn_verified` (oracle-only) moves either to the absorbing Unlearned.

`ConsentRegistry` instantiates CLSM exactly: every δ edge is one external function, and the soulbound constraint (no `transferFrom`) ensures only DS_i may transition token i.

D. Threat model

We defend five in-scope adversaries: a *lazy orchestrator* (GK reverts on pending unlearning and emits `ComplianceViolation` after the $\Delta_{\max}$ timeout), a *deceptive controller* (three MIAs plus VC t-of-n signatures), a *consent forger* (soulbound NFT and `dsOwner` check), and a *replay attacker* (UA binding $(\text{chainid}, \text{tokenId}, \text{hashPre})$); colluding participants are out of scope (an orthogonal DP layer). Six further classes are out-of-scope (Section VI); the full per-adversary model is in supplementary `docs/threat-model.md`.

E. Formal properties

ConsentChain must satisfy four properties. **Consent integrity (safety):** every participant `validateRound` admits is Active with the round purpose in its purpose set, and no δ-path returns Revoked to Active. **Enforceability (liveness):** within $\Delta_{\max}$ blocks of a revocation, either a valid UA drives the token to Unlearned or the gatekeeper logs a public `ComplianceViolation`—degrading to "no training," not "unconsented training." **Verifiability:** the oracle accepts a UA iff all three MIA scores fall below τ and t-of-n verifiers sign it. **Audit completeness:** every transition, attestation, violation, and model-hash update emits an indexed event. Safety and audit hold by construction; liveness and verifiability are shown empirically in Section V, with mechanised proofs left to future work.

IV. The ConsentChain Framework

A. On-chain access control and safety

The safety property follows by inspection of δ: no edge enters Active from Revoked/Expired, and the only edge `validateRound` fires (`tick`) guards on $\rho_r \in \mathcal{P}$; access is split so that only `unlearn_verified` is oracle-callable, five edges DS_i-controlled and two time-driven.

B. Verifiable Unlearning Protocol

On transition to Revoked/Expired, the gatekeeper sets `pendingUnlearningSince`$[i] = b$ and `validateRound` blocks all rounds (liveness). Within $\Delta_{\max}$ blocks the controller must unlearn, score the post-unlearning model with the three MIAs, assemble the Unlearning Attestation, gather t-of-n signatures, and submit it.

1) Approximate unlearning methods: ConsentChain is method-agnostic; we evaluate the three families introduced in Section II. SISA-Fed [5] retrains only the shards that touched DS_i's data; gradient ascent applies k negative-learning-rate steps $\theta^{(j+1)} = \theta^{(j)} + \eta \nabla \mathcal{L}(\theta^{(j)}; \mathcal{D}_i)$ ($k = 10$, $\eta = 10^{-4}$); and FedEraser [6] replays the aggregation history excluding DS_i with a 3-round calibration.

2) Three independent membership inference attacks: We evaluate the post-unlearning model f_{post} against DS_i's training set $\mathcal{D}_i$ (member set M) with three statistically independent attacks (so false negatives rarely coincide), each scoring in $[0, 1]$—higher meaning more residual membership signal. The *shadow-model* attack [9] is the supervised baseline: $S = 5$ shadow autoencoders yield "in"/"out" reconstruction errors that train an MLP classifier, and s_{sh} is the fraction of M it flags "in." *LiRA* [10], the strongest, calibrates a *per-example* likelihood ratio: for each $x \in M$ it fits in-/out-pool Gaussians to the log-reconstruction-errors of $n_{\text{in}} = n_{\text{out}} = 4$ reference models, and s_{lira} is the empirical TPR at an α-controlled FPR ($\alpha = 0.05$ canonical; $\alpha = 0.5$ ablation in Section VI). The *label-only* attack [11], seeing only the reconstruction decision, thresholds at FPR 0.05 and takes s_{lo} as the fraction of M below it.

3) Unlearning Attestation and hash binding: The Unlearning Attestation is the tuple $u = \langle i, h_{\text{pre}}, h_{\text{post}}, m, s^{\text{fp}}_{\text{sh}}, s^{\text{fp}}_{\text{lira}}, s^{\text{fp}}_{\text{lo}}, t_u \rangle$: the token ID, pre-/post-unlearning model hashes, method $m \in \{0, 1, 2\}$, fixed-point MIA scores $s^{\text{fp}}_j = \lfloor 10^4 s_j \rfloor$, and a timestamp. Every verifier signs the UA hash $h_u = \text{keccak256}(c \,\|\, i \,\|\, h_{\text{pre}} \,\|\, h_{\text{post}} \,\|\, m \,\|\, s^{\text{fp}}_{\text{sh}} \,\|\, s^{\text{fp}}_{\text{lira}} \,\|\, s^{\text{fp}}_{\text{lo}} \,\|\, t_u)$, where $c =$ `block.chainid`; including the chain identifier c binds the attestation to a single chain and prevents cross-chain replay.

The oracle then accepts (u, Σ) under four conditions: all three fixed-point MIA scores are below $\tau = 0.55$ (i.e. $s^{\text{fp}}_j < 5500$); at least t distinct registered verifiers, recovered from the signatures Σ, signed h_u; the pre-hash h_{pre} equals the model hash written once at revocation ($CR.$`modelHashAtRevocation`(i)); and the token is still REVOKED or EXPIRED—binding the UA to the exact model version and blocking re-attestation of an already-UNLEARNED token, closing the replay loop.

C. Three-contract Solidity architecture

ConsentChain is three Solidity 0.8.24 contracts (NatSpec in supplementary `docs/contracts-spec.md`). `ConsentRegistry` is the soulbound ERC-721 instantiating CLSM, adding a write-once `modelHashAtRevocation` and a `transitionToUnlearned` callable only by the oracle. `UnlearningOracle` holds VC, t, and $\tau^{\text{fp}} = 5500$; `submitAttestation` checks the four acceptance conditions and, on success, atomically finalises the token and unblocks the gatekeeper. `FLGatekeeper` gates rounds: `validateRound` reverts on any ineligible participant or pending unlearning (encoding liveness), and permissionless `reportTimeout` emits `ComplianceViolation` past the $\Delta_{\max}$ deadline.

a) Automation loop: A revocation fires `recordPendingUnlearning` on the gatekeeper; a valid UA reverses it via the oracle's `unblock`. Registry state thus drives the gatekeeper, and the oracle is the only path to release pending-unlearning blocks—the closed consent→unlearn→verify→attest →finalise loop that is the edge ConsentChain closes.

TABLE I
UNLEARNING EFFECTIVENESS (E6): MIA SCORES ON THE REVOKED CLIENT'S DATA, POST-UNLEARNING. THE GATE ACCEPTS IFF ALL THREE ARE BELOW $\tau = 0.55$.

Method	Shadow MIA	LiRA	Label-only	On-chain accept
No unlearning (baseline)	0.5455	0.0475	0.0060	✓
Gradient ascent	0.4380	0.0435	0.0030	✓
SISA-Fed	0.2542	0.0795	0.0862	✓
FedEraser	0.5232	0.0325	0.0050	✓
Naive retrain (exact ref.)	0.5843	0.0445	0.0138	×

V. EVALUATION

We evaluate ConsentChain on unlearning effectiveness, on-chain cost (PureChain versus Polygon Amoy), scalability of round validation to $N = 500$, and utility recovery, plus two on-chain demos validating the liveness and verifiability properties; the full reproducibility recipe is in supplementary `docs/eval-protocol.md`.

A. Experimental setup

The primary federation is a 9-client N-BaIoT autoencoder anomaly detector [12] (one client per device), a symmetric MLP ($115 \to 75 \to 50 \to 25 \to 10$) trained with FedAvg over 30 rounds (Flower, seed 42). At round 30 we simulate a GDPR Art. 17 erasure of client 5, triggering one of the three approximate methods or exact 8-client retraining. On-chain experiments run against live contracts on gas-free PureChain (PoA^2) and gas-based Polygon Amoy (PoS), with VC five ECDSA keys, $t = 3$, and $\Delta_{\max} = 1000$ blocks.

B. Unlearning effectiveness

Table I reports each method's three MIA scores on the revoked client; the `submitAttestation` predicate accepts iff all three sit below $\tau = 0.55$.

Three observations stand out. All three approximate methods produce UAs the chain accepts (shadow $0.438/0.254/0.523$ for gradient ascent/SISA-Fed/FedEraser; LiRA and label-only well below τ). The hero result: the naive-retrain baseline—never trained on client 5—yields shadow $0.584 > \tau$ and is *rejected*, because shadow reads client 5's distinctive traffic distribution, not membership [9], a confound LiRA (0.045) and label-only (0.014) avoid. Even the no-unlearning baseline sits near random ($0.55/0.05/0.01$): this federation memorises client 5 only weakly, so the gate certifies the post-model leaks no more than chance—its work is rejecting the confound, not proving prior memorisation. All three approximate UAs finalise end-to-end on PureChain to UNLEARNED.

C. On-chain cost and scalability

Table II reports per-operation gas and cost from a lifecycle ×10 run (E7; USD at POL/USD $= 0.0953$).

Per-data-subject lifecycle cost is \$0 on PureChain and \$0.00120 on Amoy. Gas counts differ modestly between the two chains, but the dominant factor at scale is gas *price* (zero versus $\sim$30 gwei), not gas count.

`validateRound`(N) scales exactly linearly in the participant count. PureChain runs the full $N \in [5, 500]$ sweep live

TABLE II
PER-OPERATION GAS AND COST (E7), LIFECYCLE ×10 MEAN. PER-DS LIFECYCLE = SUM OF THE FOUR OPS.

Operation	PureChain gas	Amoy gas	Amoy MATIC	Amoy USD
`updateModelHash`	30,074	32,673	0.0010	\$0.00009
`grantConsent`	144,868	153,568	0.0046	\$0.00044
`revokeConsent`	107,904	96,404	0.0029	\$0.00028
`submitAttestation` (3-of-5)	102,903	137,600	0.0041	\$0.00039
Per-DS lifecycle	**385,750**	**420,245**	**0.0126**	**\$0.00120**

($R^2 \approx 1$); Amoy, measured at $N \in \{5, 10\}$ and extrapolated linearly, projects to \$0.0176 per $N = 500$ round. At a typical 100-round/day cadence that is \$1.76/day per deployment on Amoy versus \$0 on PureChain: gas-free infrastructure is a different cost class, not an optimisation. Two short PureChain runs also confirm the properties empirically—a $\Delta_{\max} = 2$ timeout fires `ComplianceViolation` (liveness), and a t-of-5 sweep exercises the acceptance predicate's two branches (verifiability).

D. Utility recovery after revocation

Resuming FL for ten rounds after dropping client 5, the post-revoke model reaches reconstruction error 0.4720, 6.1% *better* than the 9-client baseline (0.5025)—client 5 was an outlier whose removal tightens the fit. Gradient ascent (0.4726) and FedEraser (0.4698) match this at no utility cost; SISA-Fed pays $+29\%$ (0.6081 by round 40), consistent with its strongest forgetting.

E. Cross-domain validation (CASAS)

On CASAS (5-client BiLSTM) the confound is sharper still: only SISA-Fed ($0.499/0.035/0.000$) passes the gate, consistent with N-BaIoT (full cross-domain results in the journal version).

VI. DISCUSSION

Limitations. Shadow MIA conflates distributional uniqueness with membership—naive retrain scored $0.584/0.846$ (N-BaIoT/CASAS) despite never seeing the data—but this is conservative by design: a compliance gate should prefer false rejection to false acceptance, so requiring *all three* MIAs below τ deliberately errs safe. LiRA resists the confound but is α-sensitive, so (α, τ) are co-calibrated per model class. ConsentChain accepts *approximate* unlearning—exact retraining being infeasible at IoT scale, GDPR Art. 17's "reasonable measures" is met by the acceptance predicate with the chain as audit evidence—leaving formal-erasure guarantees and ECDSA identity leakage (BLS-collapsed in the journal) out of scope. Off-chain training on revoked data is unpreventable, but leaves no UA binding the model to a valid consent state—a detectable omission.

Regulatory & deployment. ConsentChain discharges GDPR Arts. 7/17/21, EU AI Act Arts. 15/26, and CCPA § 1798.105 via the soulbound NFT, the $\Delta_{\max}$-bounded liveness and verifiability predicates, and audit completeness (mapping in supplementary `docs/regulatory-alignment.md`). PoA^2 is validator-permissioned yet publicly readable (apt for known-stakeholder IoT consortia), while Amoy runs the identical contracts permissionlessly: the economic model is the decision variable, not the protocol.

VII. CONCLUSION

We presented ConsentChain, the first protocol we are aware of to bind dynamic consent, machine unlearning, and on-chain verification in a single chain-enforced pipeline, closing the consent–unlearning–verification triangle prior work addressed only at the vertices: a formally-stated CLSM as soulbound ERC-721 tokens, a method-agnostic VUP gated on three independent MIAs and a t-of-n committee signature, and a three-contract architecture that runs unchanged on gas-free and gas-based EVM chains. Evaluation on a 9-client N-BaIoT [12] autoencoder, cross-validated on 5-client CASAS, confirms four numbers: per-subject lifecycle cost \$0 on PureChain versus \$0.00120 on Amoy; `validateRound` scaling linearly to $N = 500$ (\$0 versus a projected \$0.0176); MIA scores driven below $\tau = 0.55$ by approximate unlearning; and $\leq 3\%$ utility loss—indeed a 6.1% *gain* when the revoked client was an outlier. Future work targets BLS aggregation, zero-knowledge eligibility proofs, PoA^2-native verifiers, and cross-chain consent portability.

REFERENCES

[1] B. McMahan, E. Moore, D. Ramage, S. Hampson, and B. A. y Arcas, "Communication-efficient learning of deep networks from decentralized data," in *Proc. Int. Conf. on Artificial Intelligence and Statistics (AISTATS)*, 2017, pp. 1273–1282.

[2] European Parliament and Council, "Regulation (EU) 2024/1689 of the european parliament and of the council (AI Act)," Official Journal of the European Union, 2024.

[3] State of California, "California consumer privacy act of 2018 (CCPA)," Cal. Civ. Code §§1798.100 et seq., 2018.

[4] A. Azaria, A. Ekblaw, T. Vieira, and A. Lippman, "MedRec: Using blockchain for medical data access and permission management," in *Proc. IEEE Int. Conf. on Open and Big Data (OBD)*, 2016, pp. 25–30.

[5] L. Bourtoule, V. Chandrasekaran, C. A. Choquette-Choo, H. Jia, A. Travers, B. Zhang, D. Lie, and N. Papernot, "Machine unlearning," in *Proc. IEEE Symposium on Security and Privacy (S&P)*, 2021, pp. 141–159.

[6] G. Liu, X. Ma, Y. Yang, C. Wang, and J. Liu, "FedEraser: Enabling efficient client-level data removal from federated learning models," in *Proc. IEEE/ACM Int. Symposium on Quality of Service (IWQoS)*, 2021, pp. 1–10.

[7] H. Kim, J. Park, M. Bennis, and S.-L. Kim, "Blockchained on-device federated learning," *IEEE Communications Letters*, vol. 24, no. 6, pp. 1279–1283, 2020.

[8] Y. Li, C. Chen, N. Liu, H. Huang, Z. Zheng, and Q. Yan, "A blockchain-based decentralized federated learning framework with committee consensus," in *IEEE Network*, vol. 35, no. 1, 2021, pp. 234–241.

[9] R. Shokri, M. Stronati, C. Song, and V. Shmatikov, "Membership inference attacks against machine learning models," in *Proc. IEEE Symposium on Security and Privacy (S&P)*, 2017, pp. 3–18.

[10] N. Carlini, S. Chien, M. Nasr, S. Song, A. Terzis, and F. Tramer, "Membership inference attacks from first principles," in *Proc. IEEE Symposium on Security and Privacy (S&P)*, 2022, pp. 1897–1914.

[11] C. A. Choquette-Choo, F. Tramer, N. Carlini, and N. Papernot, "Label-only membership inference attacks," in *Proc. Int. Conf. on Machine Learning (ICML)*, 2021, pp. 1964–1974.

[12] Y. Meidan, M. Bohadana, Y. Mathov, Y. Mirsky, A. Shabtai, D. Breitenbacher, and Y. Elovici, "N-BaIoT: Network-based detection of IoT botnet attacks using deep autoencoders," *IEEE Pervasive Computing*, vol. 17, no. 3, pp. 12–22, 2018.

[13] D.-S. Kim, I. S. Igboanusi, and G. C. Akor, "The PureChain blockchain network: An overview," in *Proc. Int. Conf. on Mobile, Military, Maritime IT Convergence (ICMIC)*, 2025, pp. 262–265.